

CYBER SECURITY



ISO/IEC 27001 Framework

Er. Prakash Chandra Adhikari



ISO/IEC 27001



ISO/IEC 27001

Objectives of ISO/IEC 27001

- Identify information security risks
- Apply appropriate security controls
- Reduce likelihood and impact of security incidents
- Ensure business continuity
- Build trust with customers, regulators, and partners



Real Case: NIST CSF Before vs After Ransomware

PROTECT

- Weak password policy
- MFA not enforced
- Backups online and accessible
- Limited staff awareness

DETECT

- Logs not centrally monitored
- Alerts ignored or delayed
- No defined detection thresholds



Real Case: NIST CSF Before vs After Ransomware

RESPOND

- No tested Incident Response Plan
- Confusion about who should act
- Late regulator notification

RECOVER

- Backups also encrypted
- Recovery took weeks
- No structured lessons learned



Real Case: NIST CSF Before vs After Ransomware



Result:

- Long downtime
- High financial loss
- Regulatory penalties
- Loss of customer trust



Real Case: NIST CSF Before vs After Ransomware

Case Study: Implementation of NIST CSF After a Ransomware Attack

Introduction / Case Background

A **B-Class financial institution** experienced a **ransomware attack** that resulted in the encryption of critical systems, service disruption, and potential compromise of customer data. The incident exposed weaknesses in governance, security controls, detection capabilities, and recovery preparedness. To address the incident and prevent recurrence, the organization decided to implement the **NIST Cybersecurity Framework (CSF) 2.0**, which provides a **risk-based, lifecycle-oriented approach** to cybersecurity.



Real Case: NIST CSF Before vs After Ransomware

Objective of Applying NIST CSF

- The objective of implementing NIST CSF 2.0 in this case is to:
- Respond effectively to the ransomware incident
- Restore business operations securely
- Strengthen cybersecurity governance
- Reduce the likelihood and impact of future cyber attacks
- Improve overall cybersecurity maturity



Real Case: NIST CSF Before vs After Ransomware

3. Application of NIST CSF 2.0 Functions

NIST CSF 2.0 consists of six core functions: Govern, Identify, Protect, Detect, Respond, and Recover. These functions are applied as follows:

A. GOVERN (Strategic Oversight and Control)

Purpose: Establish leadership, accountability, and decision-making authority.

Actions Taken:

- Formation of a Cyber Crisis Management Committee
- Assignment of clear roles and responsibilities for incident handling
- Board-level oversight of cybersecurity risk
- Alignment of cybersecurity with enterprise risk management (ERM)

Outcome:

Cybersecurity became a governance issue rather than only an IT issue, ensuring accountability and regulatory compliance.





Real Case: NIST CSF Before vs After Ransomware

B. IDENTIFY (Understanding Assets and Risks)

Purpose: Determine what assets, data, and risks were affected.

Actions Taken:

- Identification of compromised systems and affected business services
- Classification of sensitive customer and financial data
- Conducting a Business Impact Analysis (BIA)
- Updating the cyber risk register

Outcome:

The institution gained clarity on **critical assets and risk priorities**, enabling focused protection and recovery.



Real Case: NIST CSF Before vs After Ransomware

B. IDENTIFY (Understanding Assets and Risks)

Purpose: Determine what assets, data, and risks were affected.

Actions Taken:

- Identification of compromised systems and affected business services
- Classification of sensitive customer and financial data
- Conducting a Business Impact Analysis (BIA)
- Updating the cyber risk register

Outcome:

The institution gained clarity on **critical assets and risk priorities**, enabling focused protection and recovery.



Real Case: NIST CSF Before vs After Ransomware

C. PROTECT (Preventive Safeguards)

Purpose: Limit damage and prevent further compromise.

Actions Taken:

- Isolation of infected systems
- Enforcement of strong access controls and MFA
- Securing backups using offline and immutable storage
- Conducting staff awareness training on phishing and ransomware

Outcome:

Preventive controls were strengthened to reduce the likelihood of future ransomware infections.



Real Case: NIST CSF Before vs After Ransomware

D. DETECT (Early Identification of Incidents)

- **Purpose:** Improve visibility and reduce attack dwell time.

Actions Taken:

- Centralized log monitoring and alerting
- Definition of ransomware indicators of compromise (IoCs)
- Establishment of incident escalation procedures

Outcome:

Future attacks can be **detected earlier**, minimizing operational and financial impact.



Real Case: NIST CSF Before vs After Ransomware

E. RESPOND (Incident Handling)

- **Purpose:** Contain and manage the ransomware incident.

Actions Taken:

- Execution of a formal Incident Response Plan
- Containment and eradication of ransomware
- Regulatory and stakeholder communication
- Preservation of digital evidence

Outcome:

The response became **structured, timely, and compliant**, reducing confusion and reputational damage.



Real Case: NIST CSF Before vs After Ransomware

F. RECOVER (Restoration and Improvement)

- **Purpose:** Restore operations and enhance resilience.

Actions Taken:

- Restoration of systems from clean backups
- Validation of data integrity
- Review of lessons learned
- Update of Disaster Recovery (DR) and Business Continuity Plans (BCP)

Outcome:

Operations were restored securely, and resilience against future incidents was improved.



Real Case: NIST CSF Before vs After Ransomware

4.CSF Profiles and Implementation Tiers

- **Current Profile (Before Attack):**
Tier 1–2 (Partial / Risk-Informed)
Ad-hoc controls and weak governance
- **Target Profile (After CSF Implementation):**
Tier 3 (Repeatable)
Defined policies, tested response, and continuous monitoring

A **gap analysis** was conducted, and a roadmap was created to progressively improve cybersecurity maturity.



Real Case: NIST CSF Before vs After Ransomware

5.Result and Benefits

- After implementing NIST CSF 2.0:
- Cybersecurity governance was strengthened
- Incident response and recovery time were reduced
- Regulatory confidence increased
- The organization became more resilient to ransomware attacks



Real Case: NIST CSF Before vs After Ransomware

Conclusion

In this case, the NIST Cybersecurity Framework 2.0 was used as a comprehensive, lifecycle-based framework to manage a ransomware incident. By applying its six core functions, the financial institution was able not only to respond and recover from the attack but also to strengthen governance, improve preventive controls, and enhance overall cybersecurity maturity, thereby reducing the risk of future incidents.